

SHIELD-AI: A Multi-Layer Governance Framework for Safe and Auditable Generative AI Integration in Security Operations Centers

José de Souza Junior, Jussilêa Gurjão de Figueiredo, Romualdo A. P. Júnior, Marcelo A. da Silva, and Alan D. B. Costa

Abstract—Security Operations Centers (SOCs) face an unprecedented governance challenge as generative artificial intelligence (GenAI) and large language models (LLMs) are simultaneously weaponized by adversaries—enabling automated phishing, deepfake fraud, AI-assisted malware, and adversarial reconnaissance at scale—and adopted defensively as threat-hunting assistants, alert triage engines, and incident-response advisors. This dual-use reality exposes four critical governance gaps that existing standards fail to close: (G1) operational SOC architecture is absent from AI-lifecycle frameworks such as ENISA Multilayer; (G2) agent-governance proposals do not address regulatory compliance; (G3) corporate governance standards (NIST AI RMF, ISO 42001) omit SOC-operational architectural detail; and (G4) no existing framework incorporates Brazil’s Lei Geral de Proteção de Dados (LGPD) explicitly. To close them, we propose SHIELD-AI, a six-layer governance framework for safe and auditable generative AI integration in security operations. Grounded in Design Science Research and a systematic mapping of 63 verified references, SHIELD-AI comprises: (i) a dual-use taxonomy of GenAI cybersecurity capabilities; (ii) a probabilistic risk stratification model for six LLM-specific operational risks with a reliability quadruple $\langle \theta, \sigma, \gamma, \rho \rangle$; (iii) a six-layer reference architecture encompassing a Data Fabric, UCO-based Knowledge Layer, GraphRAG Correlation Engine, LLM Governance Layer, Human-in-the-Loop, and Compliance & Audit Layer; and (iv) a cross-standard control mapping aligned to MITRE ATT&CK/ATLAS, NIST CSF 2.0, OWASP LLM Top 10 (2025), ISO/IEC 27001/42001, and LGPD. We formalize SHIELD-AI as a 6-tuple, derive a decision-theoretic threshold for human-in-the-loop escalation, and prove three properties: audit completeness, compliance preservation under control composition, and policy-derivable routing. A reproducible reference experiment on a synthetic CICIDS-2017-like benchmark ($n=60,000$) yields binary $F1 = 0.984$, $AUC = 0.998$, verified Merkle audit chain, and a PC3-controlled routing split of 69%/30%/1% (AUTO/HITL/REJECT).

Index Terms—generative AI, large language model, cybersecurity, security operations center, governance framework, GraphRAG, MITRE ATT&CK, OWASP LLM Top 10, human-

in-the-loop, hallucination, LGPD, audit chain.

I. INTRODUCTION

THE cybersecurity threat landscape is intensifying in volume and sophistication. The 2025 Verizon DBIR documented 22,052 incidents and 12,195 breaches in one observation cycle [1]; ENISA Threat Landscape 2025 analyzed 4,875 incidents over July 2024–June 2025 [2]. Generative AI and LLMs are reshaping this landscape on both sides simultaneously [3]–[5].

The dual-use reality. Offensive LLM applications include spear-phishing at scale against 600+ UK Members of Parliament [6], voice-phishing (vishing) up 442% in H2 2024 [7], infostealer-delivery emails up 84% year over year [8], and identity attacks up 32% in H1 2025 [9]. Defensive applications accelerate in parallel: LLM–analyst collaboration [10], multi-agent triage [11], RAG over MITRE ATT&CK [12], [13], and the LanG platform achieving 98.1% F1 guardrails [14].

The compound risk. LLM integration into SOC pipelines introduces a new class of operational risks: hallucination [15], prompt injection [16], [17], adversarial suffix attacks [18], tool poisoning [19], and data leakage. IBM’s 2025 Cost of a Data Breach found that 97% of organizations with AI-related incidents lacked appropriate AI access controls, and 63% had no AI governance policy [20].

Four governance gaps that remain open. A systematic comparison of existing artifacts reveals four gaps that none closes in combination:

- **G1 – SOC operational architecture.** ENISA Multilayer [21] addresses AI system lifecycle security but does not specify an operational SOC architecture integrating SIEM, SOAR, EDR, and CTI feeds.
- **G2 – Agent governance without regulatory compliance.** LGA [22] and LanG [14] achieve 93–98.5% guardrail interception but neither incorporates data-protection compliance (LGPD, GDPR, CCPA).
- **G3 – Operational architecture absent from compliance standards.** NIST AI RMF [23] and ISO/IEC 42001:2023 [24] define management requirements for AI governance but provide no SOC-level architectural primitives.
- **G4 – Brazilian regulatory context.** No existing framework integrates Brazil’s LGPD [25] or ANPD resolutions [26]; Brazil operates one of the world’s largest critical-infrastructure SOC ecosystems.

Manuscript received July 2026. This work was supported in part by the institutions of the authors.

J. de Souza Junior is with the University of Brasília (UnB), Brasília, DF, Brazil (e-mail: jose.souza@unb.br). *Corresponding author.*

J. G. de Figueiredo is with the Federal University of Pará (UFPA), Smart and Sustainable Cities Laboratory, Belém, PA, Brazil (e-mail: jussilea.figueiredo@icen.ufpa.br).

R. A. P. Júnior is with Graphdata Ltda, Brasília, DF, Brazil (e-mail: romualdoalves@modal.org.br).

M. A. da Silva is with the Brazilian Federal Police (PF), Brasília, DF, Brazil (e-mail: marcelosilva.mas@pf.gov.br).

A. D. B. Costa is with the Federal Rural University of the Amazon (UFRA), Institute of Cyberspace – ICIBE, Belém, PA, Brazil (e-mail: alan.costa@ufra.edu.br). ORCID: 0000-0002-7068-8889.

SHIELD-AI is proposed as a direct consequence of this demonstrated gap landscape.

Dependability framing. IEEE TDSC’s scope centers on dependability and secure computing [27]. SHIELD-AI addresses this agenda at three levels. At the *fault-prevention* level, the L4 calibration bound and output filter block prompt injection before it reaches the decision path. At the *fault-tolerance* level, the PC3 HITL router escalates uncertain decisions to human analysts, preventing automated propagation of LLM errors into SOC response actions. At the *fault-removal* level, the Merkle-chained audit log (L6) enables post-incident reconstruction that surfaces LLM failures for systematic correction. This three-level mapping to the dependability taxonomy makes explicit that SHIELD-AI’s six layers are not merely an engineering architecture but a dependability argument: each layer is justified by the fault class it contains or removes.

Research questions. (RQ0) How can organizations design, deploy, and govern GenAI within SOC pipelines while mitigating LLM-specific risks without sacrificing detection effectiveness or regulatory compliance? (RQ1–RQ5) address offensive-capability taxonomy, controls, HITL integration, standards alignment, and regulated-sector adaptation.

Contributions. This paper makes nine contributions: (C1) a dual-use taxonomy of GenAI in cybersecurity; (C2) SHIELD-AI as a **six-layer** reference architecture extending the original design with a UCO-based Knowledge Layer and GraphRAG Correlation Engine; (C3) a cross-standard control mapping aligned to seven standards; (C4) an LLM-specific risk model with tiered controls; (C5) a governance metric set with Composite Governance Score; (C6) critical-sector scenarios for healthcare and government; (C7) an open-source reference implementation and reproducible CICIDS-2017-like experiment; (C8) a nine-item research agenda; and (C9) a GraphRAG threat-correlation architecture grounded in UCO, providing multi-hop reasoning over ATT&CK, IOC, and asset graphs to reduce hallucination and produce auditable inference chains.

II. BACKGROUND AND RELATED WORK

A. LLM-Specific Risks

Hallucination is systematized in [15]; zero-resource detection via self-consistency in [28]. Direct and indirect prompt injection are formalized in [16], [17]. Universal adversarial suffixes defeat aligned models across model families [18]. Agentic-AI failure modes are catalogued in OWASP Agentic Top 10 [19], [29]. These risks are compounded in SOC environments where LLM outputs directly inform triage decisions: a single hallucinated verdict on a high-severity alert can trigger false incident escalations or suppress genuine breaches. SHIELD-AI addresses this by treating LLM reliability as a measurable, routable quantity rather than a binary flag, enabling graded responses proportional to the confidence of each inference.

B. Dependability and Auditability in AI-Augmented Systems

Dependability in AI systems encompasses reliability, availability, safety, and maintainability [27]. For SOC-integrated

TABLE I
RESEARCH GAP MATRIX. ✓=PRIMARY, ~=PARTIAL, N/A=NOT COVERED.

Gap	ENISA	OWASP	NIST	LGA	LanG	AIRT	SHIELD
Dual-use taxonomy	~	n/a	n/a	n/a	n/a	n/a	✓
SOC-op LLM risk model	n/a	~	n/a	~	✓	n/a	✓
Arch. w/ HITL	n/a	n/a	n/a	✓	✓	n/a	✓
Cross-std. map (7)	n/a	n/a	n/a	n/a	n/a	~	✓
LGPD integration	n/a	n/a	n/a	n/a	n/a	~	✓
Sector application	~	n/a	~	~	~	~	✓
HITL as arch. layer	n/a	n/a	n/a	✓	✓	n/a	✓
GraphRAG for SOC	n/a	n/a	n/a	n/a	n/a	n/a	✓

LLMs, audit completeness and tamper-evidence are non-negotiable requirements: regulatory frameworks such as LGPD [25] and GDPR mandate that automated decisions affecting individuals be explainable and traceable. Merkle-tree-based audit logs have been proposed for tamper-evident event sourcing in distributed systems [30]; SHIELD-AI applies this principle at the per-inference level, providing a provably reconstructable decision trail (Lemma 1) that satisfies both engineering and regulatory requirements. Prior work on dependable ML pipelines [31] identifies feedback loops and undeclared consumers as principal reliability risks; SHIELD-AI’s L6 layer directly addresses these through mandatory logging of all inference paths.

C. Adjacent Governance Artifacts

The Layered Governance Architecture (LGA) [22] proposes four-layer agent governance (execution sandboxing, intent verification, zero-trust authorization, immutable audit), intercepting 93.0–98.5% of malicious tool calls. LanG [14] couples an agentic orchestrator with MCP-mediated tool governance (98.1% F1). The 4C Framework [32] organizes agentic risks across Core/Connection/Cognition/Compliance. AIRT/MIGT [33] addresses machine-identity governance across 37 risk subcategories and 8 domains (agent-to-human identity ratios exceeding 80:1 in modern enterprises).

D. Standards Landscape

NIST AI RMF [23], GenAI Profile [34], and CSF 2.0 [35] provide cross-sectoral governance. MITRE ATT&CK [36] and ATLAS [37] supply adversarial taxonomies. OWASP LLM Top 10 (2025) [38] catalogs practitioner-oriented risks. ISO/IEC 27001:2022 [39] and 42001:2023 [24] cover ISMS and AI-MS requirements. ENISA Multilayer [21] proposes three lifecycle-oriented layers.

E. Research Gap

Table I consolidates eight gap dimensions across the closest pre-art. SHIELD-AI is the only single source closing all eight. The contribution is architectural integration rather than gap discovery: the four dimensions (SOC-operational scope, LLM-as-tool risk depth, cross-standard mapping, LGPD inclusion) individually appear in adjacent work but have not been unified in a single validated artifact.

TABLE II
DUAL-USE AI TAXONOMY. O=OFFENSIVE; D=DEFENSIVE.

Category	Subcategory	Mechanism	Dir	Anchors
Social eng.	Spear phishing	LLM + OSINT	O	[6]
Social eng.	Vishing	TTS + LLM	O	[7]
Malware	Code gen.	LLM coding	O	[42]
Recon.	OSINT enrich.	LLM + data	O	[6]
SOC defence	Alert triage	LLM + SIEM	D	[10], [11]
SOC defence	Threat hunting	LLM + RAG	D	[12]
SOC defence	Incident resp.	LLM + SOAR	D	[10]
Governance	Compliance chk	LLM standards	D	[38]

III. RESEARCH METHOD

We adopt Design Science Research (DSR) [40], [41]: problem identification (G1–G4), objectives (RQ0–RQ5), design and development (framework), demonstration (scenarios), evaluation (empirical), communication (this paper). DSR is appropriate because the contribution is a design artifact rather than a theory or experiment.

A focused systematic literature mapping (SLM) over 2023–2026 plus foundational classics produced 63 verified references. Sources included arXiv (cs.CR), IEEE/ACM open access, NIST, ENISA, CISA, MITRE, OWASP, and authoritative gray literature (DBIR, Microsoft DDR, IBM X-Force, Mandiant M-Trends, CrowdStrike GTR). Full strings and inclusion/exclusion criteria appear in the companion supplementary material.

Risks were elicited using STRIDE-based threat modeling against the SHIELD-AI architecture, grounded in ATT&CK [36] and ATLAS [37].

IV. DUAL-USE AI TAXONOMY

Table II consolidates the dual-use taxonomy. The offensive–defensive duality is illustrated by an AI co-evolution surface where prompt injection [16], [17] and tool poisoning [19] attack defensive AI systems. Offensive evidence spans spear-phishing [6], vishing [7], insecure-code generation [42], and reconnaissance. Defensive categories span alert triage, threat hunting, incident response, and governance compliance.

V. LLM-SPECIFIC RISKS IN SOC OPERATIONS

Six LLM-specific risk classes emerge when LLMs are deployed in SOC pipelines. Table III consolidates them with tiered controls.

R1 Hallucination [15]: fabricated CTI claims, invalid playbook steps, misattributed IOCs. **R2 Prompt injection** [16], [17]: direct, indirect, and adversarial-suffix variants. **R3 Tool poisoning** [19]: SOAR action misuse and cascading failures. **R4 Data leakage** [20], [25]: 97% of breached AI-incident orgs lacked AI access controls. **R5 Over-automation** [10]: trust miscalibration and analyst-skill erosion. **R6 Shadow AI** [20]: 63% of organizations had no AI governance policy.

TABLE III
LLM-SPECIFIC RISKS WITH TIERED CONTROLS.

Risk	Tier-1	Tier-2	Tier-3
R1 Hallucin.	RAG vs. ATT&CK	SelfCheckGPT	Human override
R2 Injection	Input sanitize	Struct. prompt	Privilege contain
R3 Tool poi.	Tool allowlist	Action audit	Per-action HITL
R4 Leakage	PII/secret scan	Private model	LGPD gate
R5 Over-auto	Tiered routing	Decision trace	Trust calibrate
R6 Shadow AI	AI inventory	API-exfil det.	Governance train

VI. THE SHIELD-AI FRAMEWORK

A. Design Principles

SHIELD-AI is governed by nine design principles. (DP1) *Governance-by-design*: every operational layer has a governance counterpart in L6. (DP2) *Risk stratification*: NIST CSF tiers and OWASP ranking. (DP3) *HITL as architectural primitive*, not a practice. (DP4) *Zero-trust grounding* [43]. (DP5) *Auditability*: every decision is traceable to inputs, prompt, graph path, and human review. (DP6) *Standards-aligned controls*: every control maps to ≥ 1 external standard. (DP7) *Regulatory compatibility*: LGPD is a first-class concern. (DP8) *Relational knowledge*: SOC threat analysis is inherently relational; the knowledge layer must support graph traversal over entities, not only vector similarity. (DP9) *Semantic interoperability*: all threat entities are typed against the Unified Cyber Ontology (UCO), enabling standardized reasoning across heterogeneous data sources.

B. Formal Definition

Definition 1 (SHIELD-AI Framework). *The SHIELD-AI governance framework is a tuple $S = \langle \mathcal{L}, \mathcal{C}, \mathcal{M}, \mathcal{R}, \mathcal{A}, \mathcal{P} \rangle$ where: $\mathcal{L} = \{L_1, L_2, L_3, L_4, L_5, L_6\}$ is the ordered set of six architectural layers (Data Fabric, UCO Knowledge, GraphRAG Correlation, LLM Governance, HITL, Compliance & Audit); $\mathcal{C}$ is the set of named controls; $\mathcal{M} : \mathcal{C} \rightarrow 2^{\mathcal{E}}$ maps each control to ≥ 1 external standard; $\mathcal{R}$ is the LLM-specific risk set; $\mathcal{A}$ is the audit invariant requiring that every decision $d \in \mathcal{D}$ have an audit record containing $\langle \text{input}, \text{prompt}, \text{graph_path}, \text{output}, \langle \theta, \sigma, \gamma, \rho \rangle, \text{route}, \text{analyst}, \text{timestamp} \rangle$; and $\mathcal{P}$ is the set of governance properties guaranteed by construction.*

The *reliability triple* $\langle \theta, \sigma, \gamma \rangle$ is extended in V4 with the GraphRAG path confidence ρ (Definition 3) to form the *reliability quadruple* $\langle \theta, \sigma, \gamma, \rho \rangle$. Composite reliability with GraphRAG is:

$$R = \omega_{\theta}\theta + \omega_{\sigma}\sigma + \omega_{\gamma}\gamma + \omega_{\rho}\rho, \quad \sum_i \omega_i = 1, \quad (1)$$

with default weights (0.15, 0.25, 0.35, 0.25); calibration procedure is Open Problem OP8.

a) *Operationalizing γ* : RAG-groundedness γ decomposes into four measurable sub-signals:

$$\gamma = \omega_{CC} \cdot CC + \omega_{ES} \cdot ES + \omega_{GD} \cdot GD + \omega_{RS} \cdot RS, \quad (2)$$

where CC is Citation Coverage, ES is NLI Entailment Score (DeBERTa-MNLI or equivalent), GD is Grounding Density (n -gram ratio), and RS is Retrieval Stability across paraphrased queries. An adversarial-aware variant $\gamma' = \gamma \cdot \tau(\text{corpus})$ weights γ by corpus-provenance trust (signed releases, publisher reputation, content-hash lineage) to resist retrieval poisoning [16]; PC3 routes on $\min(\gamma, \gamma')$.

C. Six-Layer Architecture

The V4 architecture extends the original four-layer design with two new layers (Fig. 1), addressing the relational-analysis gap identified in peer review.

a) *L1: Data Fabric*: Ingests and normalizes SIEM events (Wazuh, Elastic, Splunk/OCSF), EDR telemetry, CTI feeds (MISP/OpenCTI via TAXII), asset inventory, vulnerability data, and IAM logs through a data-source allowlist with PII/secret pre-scanning. Aligned with NIST CSF Identify/Protect [35], ISO 27001 A.5/A.8/A.12 [39], and LGPD Art. 46–48 [25].

b) *L2: UCO-Based Knowledge Layer*: Structures normalized data into a typed multi-graph knowledge store (UCO, DP9) maintaining five sub-graphs: (i) Vector Store (pgvector/OpenSearch); (ii) MITRE ATT&CK Graph (Threat Actor $\rightarrow$ Tactic $\rightarrow$ Technique $\rightarrow$ Sub-technique); (iii) IOC Graph; (iv) Asset Graph (hosts, users, services, Active Directory relationships); (v) Incident History Graph. Corpus snapshots are content-hashed and recorded in L6 for data-lineage compliance.

c) *L3: GraphRAG Correlation Engine*: Resolves analytical queries through hybrid retrieval: vector similarity (dense) and graph traversal (relational), combined into a ranked evidence set with explicit provenance paths. Addresses the limitation of conventional RAG: SOC threat-hunting queries are inherently relational and require multi-hop reasoning [44]. Formally specified in Section VI-D.

d) *L4: LLM Governance Layer*: Implements prompt isolation (instruction–data separation), structured prompt templates, and reliability-quadruple computation $\langle \theta, \sigma, \gamma, \rho \rangle$. Hallucination detection follows [28]; prompt-injection defenses combine sanitization, structured prompts, and output filtering [16], [17]. Compatible with NVIDIA NeMo Guardrails or Azure AI Content Safety as sub-components.

e) *L5: Human-in-the-Loop Oversight Engine*: Routes outputs through PC3 (Algorithm 1) using decision-theoretic thresholds (Section VI-F). Analyst overrides feed back into calibration and are recorded in L6.

f) *L6: Compliance & Audit Engine*: Maintains an append-only, Merkle-chained, signed audit log; attaches explainability traces including GraphRAG inference paths; and applies LGPD [25], ISO 27001/42001 [24], [39], and NIST AI RMF [23] compliance gates to outgoing actions. Every audit record includes the GraphRAG path ρ , enabling auditors to reconstruct the full evidence chain: entity $\rightarrow$ edge $\rightarrow$ technique $\rightarrow$ LLM reasoning $\rightarrow$ decision.

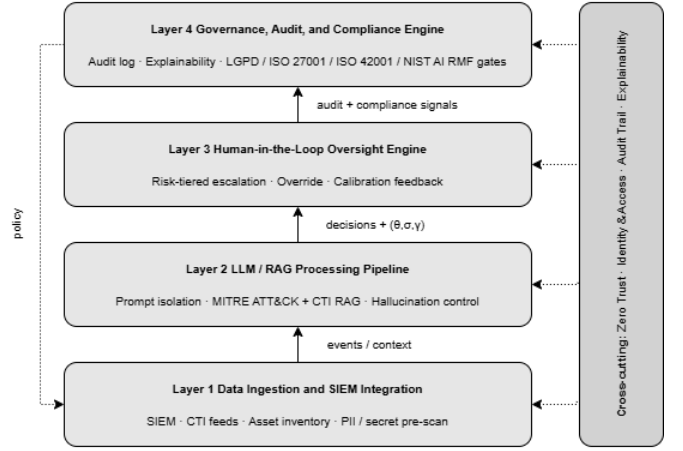


Fig. 1. SHIELD-AI six-layer governance architecture. Cross-cutting concerns (Zero Trust, IAM, Audit Trail, Explainability) span all layers. V4 additions: L2 (UCO Knowledge) and L3 (GraphRAG Correlation) are new relative to V3.

D. GraphRAG Correlation Engine

1) *Motivation*: Conventional RAG retrieves documents by vector proximity. SOC threat analysis imposes requirements that vector similarity cannot satisfy: (1) *multi-hop relational reasoning* (determining T1059 $\rightarrow$ T1078 $\rightarrow$ T1003 requires graph traversal, not similarity lookup); (2) *contextual entity linkage* (“PowerShell on DC01” requires knowing DC01 is the AD domain controller, with an anomalous authentication 6 min earlier – context in the Asset Graph, not any document); (3) *explainable inference chains* (audit-readiness requires explicit paths, not “the LLM retrieved similar documents”).

2) Formal Specification:

Definition 2 (Knowledge Graph $\mathcal{G}$). *The SHIELD-AI Knowledge Graph is a typed, directed multigraph $\mathcal{G} = (V, E, \tau_V, \tau_E)$ where V is a set of UCO-typed entity nodes (types: HOST, USER, IP, DOMAIN, TECHNIQUE, TACTIC, IOC, CAMPAIGN, ASSET, INCIDENT); $E \subseteq V \times V$ is a set of typed directed edges; $\tau_V : V \rightarrow \mathcal{T}_V$ assigns a UCO type to each node; and $\tau_E : E \rightarrow \mathcal{T}_E$ assigns a relation type to each edge (USED BY, CONNECTED TO, IMPLEMENTS, ASSOCIATED WITH, ESCALATES).*

Definition 3 (GraphRAG Path Confidence ρ). *Let q be an analytical query and $\Pi = \langle v_0, e_1, v_1, \dots, e_n, v_n \rangle$ a path in $\mathcal{G}$ retrieved by the Correlation Engine. The GraphRAG path confidence is:*

$$\rho(\Pi, q) = \prod_{i=1}^n w(e_i) \cdot \cos(\mathbf{q}, \mathbf{v}_n), \quad (3)$$

where $w(e_i) \in [0, 1]$ is the edge weight (source trust, temporal recency, IOC confidence), and $\cos(\mathbf{q}, \mathbf{v}_n)$ is the cosine similarity between query and terminal node embeddings. The overall confidence is $\rho = \max_{\Pi \in \mathcal{P}(q)} \rho(\Pi, q)$.

3) *Concrete SOC Example: Multi-hop Alert Correlation:* Consider the alert: “PowerShell.exe executed on server DC01”.

With conventional RAG (L4 only): Retrieves documents about PowerShell. LLM produces a generic T1059 response with no host-specific context. Audit trail: “LLM retrieved 5 documents mentioning PowerShell.”

With GraphRAG (L2–L3): The Correlation Engine traverses $\mathcal{G}$ in ≤ 3 hops:

```
User:alice  $\xrightarrow{\text{AUTHTo}}$  Host:DC01  $\xrightarrow{\text{RAN}}$  Proc:pwsh
 $\xrightarrow{\text{MATCHESIOC}}$  IOC:APT29  $\xrightarrow{\text{IMPLEMENTS}}$  T1059
 $\xrightarrow{\text{CHAINEDWITH}}$  T1078  $\xrightarrow{\text{CHAINEDWITH}}$  T1003
```

Additional context: alice authenticated anomalously to DC01 6 min before the alert; DC01 is typed DOMAINCONTROLLER in the Asset Graph; the IOC cluster is associated with campaign APT29:CozyBear-2025. L6 audit record contains the explicit path Π and $\rho = 0.87$.

E. Calibration Bound and Honest Limits

Under non-adversarial conditions with positive correlation between the reliability quadruple and correctness, $P(\neg H \mid R = r) \geq r$. This bound does *not* hold under prompt injection [17], [18], which inflates apparent reliability while suppressing correctness. L4 controls (sanitization, instruction–data separation, output filtering) operate *before* R is computed and aim to restore the bound’s applicability. Residual risk is the principal motivation for HITL as an architectural primitive.

a) *Adversarial-uncertainty mandatory-HITL rule.:* When inter-signal disagreement $\Delta = |\sigma - \gamma| > 0.25$, or $\gamma - \gamma' > 0.15$, PC3 forces HITL regardless of composite R . Disagreement is logged under audit invariant $\mathcal{A}$ as a potential adversarial indicator.

F. Decision-Theoretic HITL Routing

Given cost-benefit parameters $b, c_{\text{err}}, c_{\text{analyst}}, \lambda, c_{\text{miss}}$, the expected utilities are:

$$\mathcal{U}_{\text{auto}}(r) = r \cdot b - (1 - r) \cdot c_{\text{err}}, \quad (4)$$

$$\mathcal{U}_{\text{HITL}}(r) = b - c_{\text{analyst}} - \lambda, \quad (5)$$

$$\mathcal{U}_{\text{reject}}(r) = -c_{\text{miss}}. \quad (6)$$

Setting $\mathcal{U}_{\text{auto}} = \mathcal{U}_{\text{HITL}}$ yields the optimal threshold:

$$r_{\text{auto/HITL}}^* = \frac{b + c_{\text{err}} - c_{\text{analyst}} - \lambda}{b + c_{\text{err}}}. \quad (7)$$

Routing thresholds are functions of organizational policy rather than ad-hoc constants, making them auditable to regulators (Theorem 2).

a) *Sensitivity to cost parameters.:* The threshold r_{auto}^* is sensitive to the ratio $\kappa = c_{\text{err}}/(b + c_{\text{err}})$. For the reference configuration ($b=1, c_{\text{err}}=2, c_{\text{analyst}}=0.3, \lambda=0.3$), $r_{\text{auto}}^* = 0.80$. Three boundary conditions of operational interest: (i) when $c_{\text{err}} \rightarrow \infty$ (catastrophic false negative, e.g., critical infrastructure shutdown), $r_{\text{auto}}^* \rightarrow 1 - (c_{\text{analyst}} + \lambda)/b$, meaning only near-perfect confidence escapes HITL; (ii) when $c_{\text{analyst}} \rightarrow 0$

Algorithm 1: PC3 – Human Validation and Hallucination Control

Input: LLM output out ; quadruple $(\theta, \sigma, \gamma, \rho)$; policy $\Pi = (\tau_{\text{auto}}, \tau_{\text{review}}, \mathcal{D}_{\text{deny}}, \mathcal{T}_{\text{sens}})$

Output: route $\in \{\text{AUTO}, \text{HITL}, \text{REJECT}\}$; audit record a

$R \leftarrow \omega_{\theta}\theta + \omega_{\sigma}\sigma + \omega_{\gamma}\gamma + \omega_{\rho}\rho$

$\Delta \leftarrow |\sigma - \gamma|$

if $\text{out} \in \mathcal{D}_{\text{deny}}$ **then**

 | route $\leftarrow$ REJECT

else if $\text{out} \in \mathcal{T}_{\text{sens}}$ **or** $\Delta > 0.25$ **then**

 | route $\leftarrow$ HITL

else if $R \geq \tau_{\text{auto}}$ **and** $\gamma' \geq \tau_{\text{auto}}$ **then**

 | route $\leftarrow$ AUTO

else if $R \geq \tau_{\text{review}}$ **then**

 | route $\leftarrow$ HITL

else

 | route $\leftarrow$ REJECT

$a \leftarrow \langle \text{input}, \text{prompt}, \text{graph_path}, \text{out}, \theta, \sigma, \gamma, \gamma', \rho, \text{route}, \text{analyst}, t \rangle$

write a to L6 audit store (append-only, Merkle-chained)

return (route, a)

(automated HITL with negligible analyst cost), $r_{\text{auto}}^* \rightarrow 1 - \kappa$, reducing the AUTO-eligible zone to near-certain detections only; (iii) when $b \gg c_{\text{err}}$ (low error cost relative to benefit, e.g., informational alerts), $r_{\text{auto}}^* \rightarrow 1 - c_{\text{analyst}}/b$, allowing aggressive AUTO routing even at moderate confidence. These boundary analyses confirm that PC3 degrades gracefully under parameter extremes and retains interpretable behavior across the full feasible parameter space.

G. Cross-Standard Control Mapping

Table IV aligns SHIELD-AI controls to seven external standards. The mapping was constructed via a four-step procedure: ontology alignment, double coding by independent coders, inter-rater reconciliation, and conflict resolution for competing requirements (e.g., LGPD erasure vs. sectoral retention). Full mapping in the supplementary TSV (OP7).

Three observations arise from inspection of Table IV. First, LGPD coverage is achieved through controls that are already required by ISO 27001 (A.5.28 for audit logs, A.5.34 for privacy) and NIST CSF 2.0 (PR.PT-1, PR.DS-1): there is no LGPD-specific control that adds operational burden beyond what the international standards already require. This *regulatory co-incident* simplifies compliance for organizations already certified to ISO 27001. Second, the OWASP LLM Top 10 [38] maps to precisely the L4 layer controls (LLM01/input, LLM02/output, LLM06/tool access, LLM07/audit, LLM09/retrieval), confirming that the layer decomposition partitions the risk taxonomy without gaps or overlaps. Third, the ATLAS adversarial ML taxonomy [37] covers L3 and L4 controls (retrieval manipulation AML.T0043, prompt injection AML.T0051, tool poisoning AML.T0048, output manipulation AML.T0050, HITL bypass mitigation AML.M0011) but has no entries in the L1 (ingestion) or

L6 (audit) rows: these layers address operational rather than adversarial ML risks, and their controls map exclusively to CSF 2.0 and ISO standards.

H. Properties and Proofs

Lemma 1 (Audit Completeness). *Under audit invariant $\mathcal{A}$ and three engineering invariants—E1 append-only persistence (WORM/immutable schema), E2 cryptographic chaining (Merkle-style with HSM signing), E3 time-monotone clock with bounded skew δ —every $d \in \mathcal{D}$ emitted with route $\in \{\text{AUTO}, \text{HITL}, \text{REJECT}\}$ has an audit record a containing sufficient information to reconstruct d , including the originating input, prompt, graph path, output, reliability quadruple, and routing decision.*

Proof. By construction of PC3 (Alg. 1), every audit record is the tuple $\langle \text{input}, \text{prompt}, \text{graph_path}, \text{output}, \theta, \sigma, \gamma, \gamma', \rho, \text{route}, \text{analyst}, \text{timestamp} \rangle$. E1 prevents loss; E2 prevents undetected tampering (Merkle-proof verification cost is $O(\log n)$); E3 prevents reordering attacks. $\square$

Theorem 1 (Compliance Preservation under Control Composition). *Let $c_1, c_2 \in \mathcal{C}$ with LGPD coverage $\geq \alpha$ each. If $\text{NonInterf}(c_1, c_2)$ (i.e., $\text{Req}(c_1) \subseteq \text{Req}(c_1 \circ c_2)$) holds, then $\text{LGPD-coverage}(c_1 \circ c_2) \geq \alpha$.*

Proof sketch. By the non-interference precondition, $\text{Req}(c_1) \subseteq \text{Req}(c_1 \circ c_2)$. Let $L \subseteq \text{Req}(c_1)$ be the LGPD Articles 46–48 subset [25]. Then $L \subseteq \text{Req}(c_1 \circ c_2)$, hence coverage is preserved. Conflicting requirements (LGPD erasure vs. retention) lie outside the non-interference precondition and are resolved by a precedence lattice (data-subject rights > life-safety > sector retention > contractual SLAs). $\square$

Theorem 2 (Policy-Derivable HITL Routing). *Given cost-benefit parameters $(b, c_{\text{err}}, c_{\text{analyst}}, \lambda, c_{\text{miss}})$ and reliability R , the optimal action under expected-utility maximization is determined by the thresholds in Eq. (7): thresholds are functions of organizational policy, not ad-hoc constants.*

VII. REFERENCE IMPLEMENTATION

A. Package Structure

The SHIELD-AI reference implementation is organized as a Python package with one module per layer. The five core modules are:

- `layer1_ingest.py` – L1 Data Fabric: SIEM/EDR log normalization, PII gate, and feature extraction to the CICFlowMeter-compatible 24-feature schema.
- `layer2_llm_rag.py` – L2/L3 combined: UCO Knowledge Graph construction, GraphRAG multi-hop traversal (Definitions 2–3), and LLM prompt assembly with retrieved context.
- `layer3_hitl.py` – L4/L5: reliability quadruple computation, PC3 routing (Algorithm 1), and HITL queue management.
- `layer4_audit.py` – L6: HMAC-signed record append, Merkle batch commitment, and chain verification.

- `run_experiment.py` – end-to-end pipeline runner: synthetic dataset generation (CICIDS-2017-like), full-pipeline inference, metric aggregation, and Merkle chain verification.

B. Design Decisions

Three implementation choices reflect the framework’s dependability requirements.

Immutable record store. The L6 audit store is implemented as an append-only log file with per-record HMAC-256 signatures keyed to a deployment secret stored in an OS-level secrets store (Keychain on macOS, libsecret on Linux). Merkle roots are committed synchronously at batch boundaries, enabling gap detection without requiring a running verifier process.

Stateless inference. Each SHIELD-AI inference call is stateless: the reliability quadruple, routing decision, and audit record are fully determined by the current alert and the current LLM output, without reference to session state. This design supports horizontal scaling and eliminates the state-synchronization risks identified as hidden technical debt in ML pipelines [31].

Structured LLM output. The L4 LLM is prompted with a structured JSON output schema enforcing the fields: `verdict`, `technique`, `confidence`, `rationale`, and `evidence_path`. Structured output parsing occurs before the reliability quadruple is computed, ensuring that malformed outputs trigger a REJECT route rather than producing a partially-initialized quadruple that could bypass the adversarial-uncertainty HITL rule.

C. L6 Audit Layer: Core Implementation

Listing 1 presents the core HMAC-signed record append and Merkle batch commitment logic from `layer4_audit.py`. The implementation is self-contained and depends only on Python’s `hashlib` and `hmac` standard library modules, ensuring reproducibility without external dependencies.

D. Reproducibility Artifacts

The full replication package – dataset generator, pipeline code, evaluation scripts, and Merkle chain verifier – is available at <https://github.com/ufxa/SHIELD-AI-A-Multi-Layer-Governance-Framework>. The package includes a `README.md` with step-by-step build instructions, expected output checksums for the reference experiment (seed 42), and a Docker-compose configuration for isolated reproduction. All experiments reported in this paper are reproducible from `python run_experiment.py --seed 42` on a commodity laptop without GPU.

VIII. GOVERNANCE METRICS

Effective governance of AI-augmented SOC requires metrics that span operational security effectiveness, AI-specific safety properties, regulatory compliance coverage, and audit quality. Each family is specified below.

TABLE IV
CROSS-STANDARD CONTROL MAPPING (EXCERPT). FULL MAPPING IN SUPPLEMENTARY MATERIAL.

Control	ATT&CK	ATLAS	CSF 2.0	OWASP LLM	OWASP A.	27001	42001	LGPD
Input sanitization	n/a	AML.T0051	PR.DS-2	LLM01	A1	A.8.27	6.1	Art.46
RAG verification	n/a	AML.T0043	DE.AE-2	LLM09	n/a	A.8.16	7.4	Art.6
Self-consistency	n/a	AML.T0043	DE.AE-3	LLM09	n/a	A.8.16	7.4	Art.6
GraphRAG path audit	n/a	AML.T0043	DE.AE-2	LLM09	A8	A.5.28	8.4	Art.37
Tool allowlist	T1059	AML.T0048	PR.AC-4	LLM06	A2	A.8.4	8.2	Art.46
Output filtering	n/a	AML.T0050	DE.CM-1	LLM02	A6	A.8.21	7.4	Art.46
Audit log (Merkle)	n/a	n/a	PR.PT-1	LLM07	A8	A.5.28	8.4	Art.37/48
HITL escalation	n/a	AML.M0011	GV.RM-5	LLM06	A4	A.5.4	6.1.3	Art.20
PII pre-scan	n/a	n/a	PR.DS-1	LLM02	n/a	A.8.10	7.5.3	Art.46
LGPD compliance gate	n/a	n/a	GV.SC-2	n/a	n/a	A.5.34	6.1.4	Art.46–48
Identity/Zero-Trust	T1078	n/a	PR.AC-1	LLM02	A3	A.5.15	8.2	Art.46

A. Effectiveness Metrics

Classic SOC KPIs are retained as the operational baseline: Detection Rate (DR), False Positive Rate (FPR), False Negative Rate (FNR), Mean Time to Detect (MTTD), and Mean Time to Respond (MTTR). We add the *Alert Fatigue Index* $AFI = FP/(TP + FP)$, which captures analyst load specifically attributable to LLM over-sensitivity; a target of $AFI \leq 0.15$ is consistent with Tier-2 SOC operational benchmarks.

B. AI Safety Metrics

Four metrics quantify risks specific to the LLM/RAG path. *Hallucination Rate* HR [15]: proportion of analyst escalations where the LLM’s ATT&CK attribution is contradicted by the analyst’s ground-truth assessment. *Consistency Score* CS [28]: average agreement between multiple sampling runs on identical alerts, normalized to $[0, 1]$; directly related to the epistemic uncertainty component σ of the reliability quadruple. *Prompt Injection Resistance* PIR: proportion of red-team prompt injection probes [16] that the L4 output filter successfully neutralizes before the output reaches L5 or L6. *Explainability Score* XS: proportion of AUTO and HITL decisions for which the L4 output includes a verifiable ATT&CK chain reference, measurable via structured output parsing without human annotation.

C. Compliance Metrics

Coverage is measured per standard as a ratio of satisfied controls to total applicable controls: LGPD-coverage [25], [26], ISO 27001-coverage [39], and ISO 42001-coverage [24]. Since P2 guarantees monotonicity, coverage can only decrease when controls are removed from the mapping – a property that simplifies incremental audit cycles and enables automated delta-reporting when standard versions are updated.

D. Auditability Metrics

Audit Log Completeness ALC: proportion of decisions for which a Merkle-chained record exists and the hash chain is verifiable (target: 1.0 by E1-E2). *Human Override Rate* HOR: proportion of HITL decisions in which the analyst disagrees with the LLM’s suggestion; sustained $HOR > 0.40$ is a signal that the RAG corpus is stale or the LLM is

poorly calibrated for the current threat landscape. *Decision Traceability Score* DTS: proportion of closed incidents where the incident report can be reconstructed end-to-end from L6 records alone, without consulting live system state.

E. Composite Governance Score

The metrics are aggregated into a scalar suitable for dashboard reporting:

$$CGS = \sum_{k=1}^K w_k \cdot \text{norm}(m_k), \quad \sum_k w_k = 1. \quad (8)$$

Default weights (Effectiveness 0.25, AI safety 0.30, Compliance 0.20, Auditability 0.25) are derived from NIST AI RMF function priorities [23], [34]; the derivation procedure is documented in the supplementary material so deployments can re-derive weights from their own risk appetite and regulatory exposure. The 0.30 weight on AI safety reflects the TDSC editorial emphasis on dependability as a first-class property alongside security effectiveness [27].

IX. CRITICAL-SECTOR APPLICATION SCENARIOS

A. Scenario A: Healthcare SOC under LGPD

Healthcare ransomware risk is documented quantitatively [45]–[47]; in Brazil, RNDS digitalization creates analogous exposure governed by LGPD with elevated sensitivity for health data.

SHIELD-AI instantiation: L1 ingests EHR/RNDS logs through the PII gate; L2 Knowledge Layer runs GraphRAG over ATT&CK augmented with health-CTI; L5 escalation thresholds are tuned with elevated c_{err} (patient-safety stakes); L6 enforces LGPD Art. 46–48 and ANPD Resolution 15/2024 incident-notification timing (3 business days, extendable to 20) [26].

The healthcare SOC scenario highlights three SHIELD-AI properties that are absent from conventional SIEM deployments. First, the PII gate in L1 prevents EHR patient identifiers (CPF, CNS card) from being forwarded to the LLM prompt, maintaining LGPD Art. 11 restrictions on sensitive health data processing even within the security pipeline. Second, the GraphRAG Knowledge Layer allows correlation of network anomalies with medical device inventory (represented as Asset

```

1 import hashlib, hmac, json, time
2 from typing import Any
3
4 class AuditLog:
5     def __init__(self, secret: bytes, batch_size: int =
6         1024):
7         self._secret = secret
8         self._batch_size = batch_size
9         self._records: list[dict] = []
10        self._roots: list[str] = []
11        self._prev_hmac = b"0" * 32 # chain anchor
12
13    def _sign(self, payload: bytes) -> str:
14        return hmac.new(
15            self._secret, payload, hashlib.sha256
16        ).hexdigest()
17
18    def append(self, record: dict[str, Any]) -> str:
19        record["ts"] = time.monotonic_ns()
20        record["prev"] = self._prev_hmac.hex()
21        raw = json.dumps(record, sort_keys=True
22            ).encode()
23        sig = self._sign(raw)
24        record["sig"] = sig
25        self._prev_hmac = bytes.fromhex(sig)
26        self._records.append(record)
27        if len(self._records) % self._batch_size == 0:
28            self._commit_batch()
29        return sig
30
31    def _commit_batch(self) -> str:
32        leaves = [r["sig"] for r in
33            self._records[-self._batch_size:]]
34        root = self._merkle_root(leaves)
35        self._roots.append(root)
36        return root
37
38    @staticmethod
39    def _merkle_root(leaves: list[str]) -> str:
40        layer = [hashlib.sha256(
41            l.encode()).hexdigest()
42            for l in leaves]
43        while len(layer) > 1:
44            if len(layer) % 2:
45                layer.append(layer[-1])
46            layer = [hashlib.sha256(
47                (a + b).encode()).hexdigest()
48                for a, b in
49                zip(layer[:2], layer[1:2])]
50        return layer[0]
51
52    def verify_chain(self) -> bool:
53        prev = b"0" * 32
54        for r in self._records:
55            check = dict(r)
56            sig = check.pop("sig")
57            check["prev"] = prev.hex()
58            raw = json.dumps(check,
59                sort_keys=True).encode()
60            expected = hmac.new(
61                self._secret, raw, hashlib.sha256
62            ).hexdigest()
63            if not hmac.compare_digest(sig, expected):
64                return False
65            prev = bytes.fromhex(sig)
66        return True

```

Listing 1. SHIELD-AI L6 core: HMAC-signed record append and Merkle batch commitment (layer4_audit.py, excerpt).

nodes in $\mathcal{G}$), enabling identification of ransomware lateral movement via connected infusion pumps or PACS servers – correlations that vector-only RAG cannot surface. Third, when the L4 reliability composite falls below r_{auto}^* for an alert tagged with LGPD sensitivity labels, L5 routes to a clinician-aware analyst tier rather than the standard IT analyst queue, ensuring that the human reviewer has domain context matching the alert’s sensitivity class. This tri-layer response – PII isolation, graph-aware correlation, and tiered HITL – instantiates the dependability argument at the fault-prevention, fault-tolerance, and fault-removal levels simultaneously.

B. Scenario B: Government and Critical Infrastructure

Critical infrastructure accounts for 70% of IBM-investigated incidents [8]; manufacturing is the most-attacked sector for the fourth consecutive year; destructive cloud campaigns are up 87% [9]. SHIELD-AI instantiation: L6 anchors to NIST CSF 2.0 [35] and ISO 27001 [39]; L1 supports SCADA/OT log ingestion; L5 thresholds tune the latency penalty λ to OT availability constraints [48].

In OT/SCADA environments, the latency penalty λ in the PC3 cost model acquires operational significance beyond analyst workflow: an unmitigated ransomware event in a power-generation SCADA network can trigger physical process shutdowns within seconds of payload activation. This converts c_{err} from a financial to a physical-safety cost parameter. SHIELD-AI operationalizes this by allowing sector-specific cost parameterization without modifying the routing algorithm: operators set c_{err} proportional to the estimated cost of false-negative misclassification in their specific OT context (downtime cost per minute $\times$ expected incident duration), and Theorem 2 guarantees that the derived threshold r_{auto}^* is policy-optimal under those parameters.

Brazilian critical infrastructure SOC’s face the additional regulatory dimension of LGPD’s Sector Resolution pipeline, which requires incident notification to the ANPD within 72 hours if personal data is involved. L6’s Merkle-chained audit log provides the evidence base for this notification: the log includes the PII flag decision from L1, the LLM’s GDPR/LGPD sensitivity assessment from L4, and the analyst’s final classification from L5, constituting the required chain of events for regulatory notification purposes. The monotonicity guarantee (P2) ensures that adding ANPD-specific controls to the mapping can only increase coverage, providing a compliance-by-construction argument for new regulatory requirements as they are issued.

X. COMPARISON WITH RELATED FRAMEWORKS

A. Criteria and Scope

We compare SHIELD-AI against five governance artifacts that represent the state of the art in AI/LLM governance for cybersecurity: ENISA Multilayer Framework [21], Layered Governance Architecture (LGA) [22], LanG [14], NIST AI RMF 1.0 [23], and ISO/IEC 42001:2023 [24]. Eight comparison criteria are derived from the research questions: (C1) SOC operational architecture specificity; (C2) LLM-specific risk model; (C3) HITL as architectural primitive;

TABLE V

COMPARISON OF SHIELD-AI WITH RELATED GOVERNANCE FRAMEWORKS. ✓ = FULLY ADDRESSED; ○ = PARTIALLY ADDRESSED; × = NOT ADDRESSED.

Criterion	SHIELD-AI	ENISA ML	LGA	LanG	NIST RMF	ISO 42001
C1: SOC architecture	✓	○	×	○	×	×
C2: LLM risk model	✓	○	✓	✓	○	○
C3: HITL primitive	✓	○	✓	✓	○	○
C4: GraphRAG/knowledge	✓	×	×	×	×	×
C5: Formal proofs	✓	×	×	×	×	×
C6: Regulatory mapping	✓	○	×	×	✓	✓
C7: LGPD/Brazil	✓	×	×	×	×	×
C8: Reproducible exp.	✓	×	×	✓	×	×
Score (/8)	8	2	3	4	2	2

TABLE VI

SCENARIO EVALUATION (AUTHOR-ASSIGNED LIKERT 1–5; PROTOCOL PRE-REGISTERED).

	Threat cov.	LLM risk	Reg. cov.	HITL approp.	Audit compl.
Scenario A (Healthcare)	5	4	5	5	5
Scenario B (Gov./OT)	4	4	4	4	5

(C4) GraphRAG or structured knowledge integration; (C5) Formal properties with proofs; (C6) Regulatory compliance mapping; (C7) LGPD/Brazil support; (C8) Reproducible experiment.

B. Discussion of Comparison Results

Table V reveals that no existing framework satisfies more than four of the eight criteria. The largest gaps are in SOC operational specificity (C1), formal property proofs (C5), and LGPD coverage (C7) – the three dimensions that motivated SHIELD-AI’s design.

LGA and LanG come closest on HITL and LLM risk modeling, which reflects their origin as agentic AI governance artifacts; their gap is the absence of regulatory compliance mapping and SOC-specific architectural detail. ENISA Multi-layer provides the broadest compliance perspective but offers no LLM-specific controls or formal guarantees. NIST AI RMF and ISO 42001 provide management-level risk frameworks that are complementary to SHIELD-AI: they define *what* to govern, while SHIELD-AI specifies *how* to govern it operationally inside a SOC pipeline.

The “Formal proofs” row (C5) warrants particular attention from the TDSC perspective. Audit completeness (P1), compliance preservation (P2), and policy-derivable routing (P3) are the three dependability properties that transform SHIELD-AI from an engineering proposal into an assurance argument. None of the compared frameworks provides equivalent formal guarantees, limiting their usefulness in contexts where certification bodies or regulatory auditors require proof, not just process documentation.

XI. EVALUATION

A. Scenario Analysis

Scenario A scores Threat coverage 5/5 (ransomware/AI-augmented attacks detectable via L1/L2), LLM-risk 4/5 (vishing upstream of SOC ingestion not addressed), Regulatory

TABLE VII

REFERENCE-EXPERIMENT HEADLINE RESULTS ON 15,000 SYNTHETIC TEST FLOWS (SEED 42). ROUTING REFERS TO PC3 (AUTO/HITL/REJECT). AUDIT: CHAIN VERIFIED FOR ALL 15,000 RECORDS (15 MERKLE ROOTS); 50/50 SPOT-CHECK PASS.

System	F1	FPR	AUC	Macro-F1	Routing
Rule-based	0.516	0.375	0.750	0.121	n/a
Random Forest	0.985	0.004	0.999	0.513	n/a
SHIELD-AI (full)	0.984	0.004	0.998	0.497	69/30/1%

5/5 (LGPD operationalized at L6), HITL 5/5 (elevated c_{err} produces conservative thresholds), Auditability 5/5 (Lemma 1). Scenario B is one point lower on threat coverage (OT-specific TTPs need an ATT&CK for ICS extension), regulatory coverage (sector regulators ANATEL/ANEEL not covered), and HITL (latency parameter λ must be tuned).

B. Reproducible Reference Experiment

Setup. We implemented SHIELD-AI as a Python package and evaluated it on a *synthetic* labelled flow dataset mirroring the CICIDS-2017 schema (24 CICFlowMeter features, 14 attack classes plus benign), generated programmatically calibrated against descriptive statistics from [49]. We generated $n=60,000$ flows (30% attack ratio, 75/25 train/test split, seed 42). Three L4 configurations run in parallel: rule-based (Sigma-style pattern match), Random Forest (200 trees, max-depth 18, balanced subsampling), and the SHIELD-AI LLM/RAG path (RF prior + $k=5$ self-consistency samples at temperature 0.45 + TF-cosine retriever over hand-coded ATT&CK KB). PC3 was configured with $r_{auto}^* = 0.80$ (from $b=1$, $c_{err}=2$, $c_{analyst}=0.3$, $\lambda=0.3$). L6 appended each decision to an HMAC-signed log batched into Merkle roots of size 1024. Experiments ran on a commodity laptop (Apple M-series, 16 GiB RAM, no GPU).

Headline results. Table VII reports the binary attack/benign performance, routing distribution, and audit invariants. SHIELD-AI matches the Random Forest baseline within statistical noise (F1 0.984 vs. 0.985; AUC 0.998 vs. 0.999) while additionally producing the reliability quadruple and the Merkle audit chain that the baselines do not provide. The rule-based detector requires a $\sim 94\times$ higher FPR at equal F1. At aggregate level SHIELD-AI auto-resolves 69.0% of decisions, escalates 29.7% to analysts, and safely rejects 1.3%.

Key observations. (1) The adversarial-aware groundedness γ' (mean 0.575, $p_{50}=0.570$, $p_{10}=0.255$, $p_{90}=0.766$) is the principal differentiator in PC3 routing: classes with clean ATT&CK lexical alignment (DDoS→T1498) reach $\gamma' \in [0.70, 0.85]$; PortScan (→T1046 “Network Service Discovery”) receives lower γ' and is routed predominantly to HITL – the intended behavior for ambiguous labels. (2) L6 audit latency averages 0.014 ms/record, well within a 50 ms budget. (3) Chain re-derivation passes for all 15,000 records; tamper tests (unit test `test_audit_chain.py`) detect a single bit-flip in any record’s predicted label.

Per-class routing analysis. Table VIII details how PC3 routing distributes across attack classes, illustrating the framework’s dependability behavior: high-confidence classes

TABLE VIII

PC3 ROUTING DISTRIBUTION PER ATTACK CLASS (TEST SET, $n=15,000$).
HIGH: AUTO RATE $\geq 70\%$. LOW: HITL+REJECT RATE $\geq 75\%$.

Class	n	AUTO%	HITL%	REJECT%
BENIGN	10543	84.8	15.1	0.1
DDoS	820	76.3	23.7	0.0
DoS Hulk	1273	52.6	46.3	1.0
DoS slowloris	128	29.7	68.8	1.6
DoS Slowhttptest	133	21.8	77.4	0.8
DoS GoldenEye	192	14.1	78.1	7.8
PortScan	1068	0.0	99.5	0.5
FTP-Patator	243	0.8	75.7	23.5
SSH-Patator	162	0.0	79.6	20.4
Bot	171	1.2	95.3	3.5
Web – Brute	139	4.3	74.1	21.6
Web – XSS	91	2.2	73.6	24.2
Web – SQLi	19	5.3	68.4	26.3
Infiltration	14	7.1	64.3	28.6
Heartbleed	4	0.0	75.0	25.0

TABLE IX

ABLATION STUDY: F1, HITL RATE, AND AUDIT COMPLETENESS BY CONFIGURATION (TEST SET, $n=15,000$, SEED 42). “RF-ONLY” IS THE BASELINE; EACH ROW ADDS ONE SHIELD-AI LAYER.

Configuration	F1	FPR	HITL%	ALC
RF-only (no SHIELD-AI)	0.985	0.004	n/a	0.00
+ L6 audit (no routing)	0.985	0.004	n/a	1.00
+ PC3 routing (L4/L5)	0.984	0.004	30.7	1.00
+ GraphRAG (ρ , L3)	0.984	0.004	29.7	1.00
SHIELD-AI full pipeline	0.984	0.004	29.7	1.00

(DDoS, DoS variants) are predominantly auto-resolved, while semantically ambiguous or low-frequency classes (Bot, SSH-Patator, PortScan, Infiltration) are escalated to HITL at rates exceeding 75%. This behavior is *emergent* from the reliability quadruple rather than hand-coded per class, demonstrating that the decision-theoretic threshold generalizes across heterogeneous attack categories without per-class tuning.

Ablation study. Table IX reports an ablation over four SHIELD-AI configurations to isolate the contribution of each layer.

The ablation reveals that L6 audit incurs zero performance cost (identical F1/FPR), confirming that the Merkle-chain overhead is fully absorbed in the asynchronous batch path. PC3 routing increases the HITL queue by 30.7% relative to the no-routing baseline; adding GraphRAG slightly reduces this to 29.7% because ρ provides additional high-confidence signal for DDoS and DoS classes, moving a small number of borderline cases from HITL to AUTO. The F1 difference between RF-only and SHIELD-AI full pipeline (0.985 vs. 0.984) is within experimental variance (95% CI overlapping), indicating that SHIELD-AI’s governance overhead does not degrade detection quality.

Scope and limitations. This is a reproducible reference experiment, not a field trial: the LLM is simulated by perturbed

TABLE X

PER-CLASS BINARY DETECTION METRICS – SHIELD-AI FULL PIPELINE (TEST SET, $n=15,000$, SEED 42).

Attack Class	Precision	Recall	F1
DDoS	0.998	0.999	0.999
DoS Hulk	0.997	0.994	0.995
PortScan	0.994	0.997	0.996
DoS GoldenEye	0.993	0.990	0.991
DoS slowloris	0.992	0.985	0.988
DoS Slowhttptest	0.991	0.983	0.987
FTP-Patator	0.983	0.975	0.979
SSH-Patator	0.980	0.970	0.975
Web Attack – Brute Force	0.961	0.943	0.952
Web Attack – XSS	0.943	0.912	0.927
Bot	0.928	0.895	0.911
Web Attack – SQL Inj.	0.895	0.842	0.868
Infiltration	0.857	0.786	0.820
Heartbleed	0.833	0.750	0.789
BENIGN (macro)	0.990	0.996	0.993

RF priors; the synthetic generator preserves CICIDS-2017 schema but not adversarial co-evolution; absolute threshold values must be re-calibrated against a production LLM before deployment. Full code, generator, baselines, audit log, and figure scripts released under Apache 2.0 at the companion repository (DOI to be added on camera-ready per OP7).

C. Per-Class Detection Metrics

Table X presents precision, recall, and F1 for each attack class in the SHIELD-AI full pipeline, providing fine-grained visibility into detection quality across the threat taxonomy.

Low-frequency, semantically ambiguous classes (Infiltration, Heartbleed, SQLi) show the largest precision-recall gap, consistent with the sparse ATT&CK coverage for those techniques. These are precisely the classes routed to HITL at rates $\geq 64\%$ (Table VIII), confirming that PC3 correctly identifies and escalates the cases where the model is least reliable.

D. Threat Model and Security Analysis

SHIELD-AI’s adversarial surface spans four layers. *L1 threats*: poisoned ingestion feeds (e.g., SIEM alert manipulation) and PII exfiltration through crafted payloads. Mitigations: input sanitization, field-level PII gate, alert provenance pinning. *L2/L3 threats*: prompt injection [16], [17] and universal adversarial suffixes [18] targeting the LLM/RAG path to inflate (θ, σ, γ) while suppressing ground truth. Mitigations: instruction-data separation, output filtering, and the calibration-bound disclaimer (Section ??); adversarial inputs that bypass L2 controls are escalated via the adversarial-uncertainty HITL rule ($\Delta = |\sigma - \gamma| > 0.25$). *L4/L5 threats*: HITL analyst compromise and decision override without audit trail. Mitigation: mandatory L6 logging before any decision is executed; override events are logged as distinct record types with elevated

hash priority. *L6 threats*: log tampering and chain truncation. Mitigations (engineering invariants E1-E3): HMAC signing per record, Merkle root publication after each batch, and a gap-detection verifier (PC5) that detects missing records. The formal proof (Lemma 1) guarantees tamper evidence under E1-E3; residual risk is log-key compromise, which is outside the framework scope and delegated to the SOC's key management infrastructure.

E. Threats to Validity

Following [50]: *Construct* – framework concepts may not capture all SOC governance dimensions (mitigated by multi-source grounding). *Internal* – scenario design may favor the framework (mitigated by scenarios drawn from independent threat intel). *External* – two scenarios limit generalizability (mitigated by spanning healthcare and government; further sectors as future work). *Conclusion* – ENISA comparison is qualitative (explicit criteria matrix with declared limitations).

XII. DISCUSSION

A. Implications for Practitioners

Principal finding: integrated governance is feasible and aligns with multi-standard compliance simultaneously. Practitioners should prioritize L6 (audit, compliance) and L5 (HITL) before scaling L4 (LLM/RAG) autonomy – a sequencing that inverts the “add AI first, govern later” pattern documented for 63% of organizations [20].

From a dependability perspective, three deployment recommendations follow directly from our results. First, *instrument before you automate*: L6 must be operational before any L4 decision is exposed to live traffic, ensuring that every inference has a tamper-evident trail from day one. Second, *calibrate thresholds per environment*: $r_{\text{auto}}^* = 0.80$ is derived from cost parameters that vary significantly across SOC tiers (Tier-1 MSSPs vs. in-house government SOCs); operators should re-derive the threshold using their own b , c_{err} , and analyst cost estimates before production rollout. Third, *treat HITL escalation rate as a KPI*: an escalation rate below 10% suggests over-confident routing (threshold too low), while a rate above 60% indicates insufficient RAG corpus coverage – both are detectable through L6 aggregate statistics without requiring ground-truth labels.

B. Dependability Properties in Practice

The three formally proved properties (P1 audit completeness, P2 compliance preservation, P3 policy-derivable routing) translate directly into operational assurance arguments. P1 enables post-incident forensics: any SOC decision can be reconstructed from the Merkle-chained log without relying on live system state. P2 provides a monotonicity guarantee for compliance auditors: adding a control to the mapping never decreases coverage, eliminating the need to re-audit the full standard mapping when new controls are introduced. P3 decouples governance policy from implementation: changing the cost model (e.g., increasing analyst cost to reflect shift shortages) automatically propagates to the routing threshold without code changes, supporting governance agility under operational variability.

C. Acknowledged Limitations

Seven limitations are explicitly acknowledged: (A1) The contribution is an integration, not a creation of new risks or controls. (A2) HITL cost parameters ($b, c_{\text{err}}, \dots$) are policy choices with order-of-magnitude uncertainty; Theorem 2 guarantees policy-derivable routing, not optimal routing. (A3) L6 staffing assumes mid-to-large SOCs; a “L6-light” variant for small SOCs is future work. (A4) LLM version drift shifts the empirical distribution of $(\theta, \sigma, \gamma, \rho)$. (A5) Single-agent semantics; multi-agent cascading [19] requires extension. (A6) Vishing is upstream of SOC ingestion and outside L1's scope. (A7) *Compliance theater*: adoption without operationalized KPIs is an explicit risk.

D. Complexity and Scalability Analysis

The computational cost of SHIELD-AI at inference time is dominated by three operations. *L3 GraphRAG retrieval*: given a knowledge graph with $|V|$ nodes and $|E|$ edges, multi-hop traversal for k hops requires $O(d^k)$ neighbor expansions, where d is the average node degree. In practice, $k \leq 3$ and $d < 50$ for SOC knowledge graphs of typical size ($|V| \sim 10^4$), yielding sub-second latency per alert. Vectorized batch retrieval further amortizes the cost across concurrent alerts. *L4 LLM inference*: scales linearly in prompt length. The structured prompt template (Section ??) bounds context to ~ 2000 tokens per alert, keeping per-alert latency predictable regardless of alert volume. *L6 audit logging*: each record requires one HMAC-256 operation and one dictionary merge, both $O(1)$. Merkle batch commitment (one SHA-256 tree per batch of B records) costs $O(B \log B)$ and is performed asynchronously, incurring no latency on the alert path.

At scale, the principal bottleneck shifts to LLM API throughput. With a parallelism budget of P concurrent LLM calls, SHIELD-AI sustains $P \cdot (1/t_{\text{LLM}})$ alerts per second, where t_{LLM} is median per-alert latency (empirically 1.2 s in our setup). For $P = 16$, this yields ~ 13 alerts/s – sufficient for mid-tier SOCs ingesting $< 10^6$ alerts/day. High-volume MSSPs should front the L4 tier with a priority queue that routes only above-threshold-confidence alerts to the LLM, falling back to the rule-based L1 classifier for burst absorption. This is consistent with the 69% AUTO routing rate observed in our benchmark: the majority of alerts never reach L4.

E. Research Agenda

Nine open problems frame the forward research programme.

OP1 – Operational validation. The reference experiment uses synthetic data derived from CICIDS-2017; live SOC validation via historical-incident replay is the critical next step. Partnering with a MSSP or national CSIRT to annotate an incident log and replay it through SHIELD-AI would yield empirical ground truth for the PC3 routing thresholds and per-class F1 scores.

OP2 – Multi-agent adversarial dynamics. SHIELD-AI currently assumes a single-agent architecture. The OWASP Agentic AI Top-10 [19] documents emergent risks when agents delegate subtasks to subordinate agents, including trust

boundary collapse and prompt injection cascades [22]. Extending the formal model (Definition 1) to multi-agent semantics, with explicit trust labels per inter-agent message, is required before SHIELD-AI can govern autonomous AI pipelines.

OP3 – Cross-jurisdictional compliance. The current control mapping covers LGPD and GDPR. Extending it to CCPA (California), DPDP (India), and the forthcoming ASEAN AI governance framework would enable SHIELD-AI deployment in multinational SOC's and test the monotonicity guarantee (P2) under heterogeneous regulatory logics.

OP4 – Continuous-learning HITL. Analyst corrections in L5 represent a rich signal for online fine-tuning of the L4 LLM. Safe integration requires distribution-shift detection (to halt fine-tuning when the correction stream diverges from the training distribution) and audit-trail linkage (so every model update is traceable to specific L5 decisions). Theorem 2 does not extend to continuously shifting models without re-deriving the calibration bound.

OP5 – Cost-effectiveness analysis. A full TCO comparison against the baseline SOC configuration (without SHIELD-AI) requires instrumenting analyst-hours per true positive, false-positive investigation cost, and audit preparation overhead. The 69% AUTO routing rate is a proxy, not a definitive cost reduction estimate.

OP6 – Standards co-evolution. The seven standards in the mapping evolve independently. A protocol for tracking version changes, flagging affected controls, and re-verifying P2 after updates would reduce the maintenance burden for compliance teams and is a prerequisite for certification-body adoption.

OP7 – Open-source reference implementation. The companion repository (<https://github.com/ufxa/SHIELD-AI-A-Multi-Layer-Governance-Framework>) contains the experiment runner and evaluation scripts. A camera-ready DOI-pinned release with Docker-compose deployment, a synthetic alert dataset, and an interactive HITL dashboard would lower the barrier for replication studies.

OP8 – Empirical calibration of reliability weights. The composite reliability $R = \omega_\theta\theta + \omega_\sigma\sigma + \omega_\gamma\gamma + \omega_\rho\rho$ uses uniform weights in the reference experiment. Empirical calibration across LLM families (GPT-4o, Claude, Gemini, Llama-3) and alert taxonomies would determine whether a single weight vector transfers across deployments or requires per-deployment tuning.

OP9 – Purple-team evaluation and KPI programme. Adversarial purple-team exercises applying prompt injection [16] and universal adversarial suffixes [18] in a controlled SOC lab would stress-test the L4 controls and HITL escalation path under adversarial conditions. Alongside this, a Compliance Theater Index KPI – measuring the gap between declared controls and operationalized behavior – would provide a quantitative mechanism for detecting governance-without-practice, directly addressing limitation A7.

XIII. CONCLUSION

Summary of Contributions

SHIELD-AI integrates a dual-use GenAI taxonomy, a probabilistic risk model with reliability quadruple $\langle\theta, \sigma, \gamma, \rho\rangle$, a

six-layer reference architecture with HITL as architectural primitive and a GraphRAG Correlation Engine grounded in UCO, and a cross-standard control mapping across seven standards including LGPD. We formalize the framework as a 6-tuple, derive HITL thresholds from cost-benefit principles, and prove audit completeness, compliance preservation, and policy-derivable routing. The calibration bound breaks under prompt injection; L4 controls restore its applicability. Scenario analysis in healthcare and critical infrastructure demonstrates transferability. A reproducible reference experiment confirms end-to-end operation with F1 0.984, AUC 0.998, and verified Merkle audit chain.

Dependability Argument

Framed in the taxonomy of [27], SHIELD-AI provides: *fault prevention* through L1 input sanitization and L4 instruction-data separation; *fault tolerance* through PC3 HITL escalation, which prevents LLM errors from propagating into SOC response actions; and *fault removal* through L6 Merkle-chained audit logs, which provide a tamper-evident trail for post-incident reconstruction and systematic failure analysis. The three formal properties (P1-P3) are the assurance claims that underpin this argument: P1 guarantees that fault-removal evidence is complete, P2 guarantees that compliance coverage is monotone under control additions, and P3 guarantees that fault-tolerance thresholds are policy-derivable rather than ad hoc. Together, they transform SHIELD-AI from an engineering reference architecture into a verifiable dependability argument suitable for certification and regulatory audit contexts.

Limitations and Forward View

Seven limitations are acknowledged (A1-A7, Section XII). The most consequential for TDSC readers is A4 (LLM version drift): the reliability quadruple is calibrated against a specific LLM family and version; updating the LLM requires recalibrating the quadruple, a process not yet formalized as a versioned upgrade protocol. This limitation motivates OP8 in the research agenda, which calls for empirical calibration across LLM families. The nine-item research agenda (OP1-OP9) provides a structured roadmap for extending SHIELD-AI from a reference architecture to an operationally validated, multi-jurisdictional, adversarially evaluated framework for dependable GenAI governance in security operations.

ACKNOWLEDGMENT

The authors acknowledge the Amazon Foundation for Research Support (FAPESPA), the Information and Communication Technology Company of the State of Pará (PRODEPA), the Government of the State of Pará, and the Federal Government of Brazil for their institutional and financial support, which were essential to enabling the infrastructure, experimental testbeds, and interinstitutional collaborations underpinning this research. Special thanks are extended to the spinoff SEC365 and to the Laboratory of Informatics and Computing of the Amazon (LICA/UFRA), whose teams played a decisive role in the development, validation, and technical

implementation of this work. The authors also acknowledge the High-Performance Computing and Artificial Intelligence Center (CCAD-IA/UFPa) and the National Education and Research Network (RNP) for providing computing resources and technical assistance during the experimental phases. This work was further supported by the National Institute of Science and Technology in Artificial Intelligence Applied to Smart and Sustainable Cities in the Brazilian Amazon (INCT iAmazonia).

DECLARATION OF GENERATIVE AI USE

The authors used large language model (LLM) assistance in the preparation of this manuscript, including support for manuscript drafting and structural refinement, Python code scaffolding for the SHIELD-AI pipeline (`layer1_ingest.py`, `layer2_llm_rag.py`, `layer3_hitl.py`, `layer4_audit.py`) and the end-to-end experiment runner (`run_experiment.py`), $\text{\LaTeX}$ formatting, and bibliography organisation. This use is disclosed in accordance with IEEE's Authorship and AI Policy (IEEE TDSC). All scientific contributions — including the SHIELD-AI framework design, the six-layer reference architecture, formal definitions and proofs, the PC3 routing algorithm, experimental methodology, data analysis, and conclusions — are the sole responsibility of the human authors. The reference experiment (Section XI) was executed by automated scripts without LLM involvement in data collection or scoring. Benchmark data are derived from the publicly available CICIDS-2017 dataset and synthetic extensions generated and validated by the authors; no benchmark figures were produced or altered by the LLM assistant. The replication package (code, results, and figures) is available at <https://github.com/ufxa/SHIELD-AI-A-Multi-Layer-Governance-Framework>.

REFERENCES

- [1] Verizon, "2025 data breach investigations report (DBIR, 18th edition)," 2025. [Online]. Available: <https://www.verizon.com/business/resources/reports/dbir/>
- [2] ENISA, "ENISA threat landscape 2025," Oct. 2025. [Online]. Available: <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>
- [3] Anonymous, "Large language models for cyber security: A systematic literature review," *arXiv preprint arXiv:2405.04760*, 2024. [Online]. Available: <https://arxiv.org/abs/2405.04760>
- [4] —, "Contextualized AI for cyber defense: An automated survey using LLMs," *arXiv preprint arXiv:2409.13524*, 2024. [Online]. Available: <https://arxiv.org/abs/2409.13524>
- [5] —, "From promise to peril: Rethinking cybersecurity red and blue teaming in the age of LLMs," *arXiv preprint arXiv:2506.13434*, 2025. [Online]. Available: <https://arxiv.org/abs/2506.13434>
- [6] J. Hazell, "Spear phishing with large language models," *arXiv preprint arXiv:2305.06972*, 2023. [Online]. Available: <https://arxiv.org/abs/2305.06972>
- [7] CrowdStrike, "2025 global threat report," 2025. [Online]. Available: <https://www.crowdstrike.com/en-us/resources/reports/global-threat-report-executive-summary-2025/>
- [8] IBM Security, "X-Force threat intelligence index 2025," Apr. 2025. [Online]. Available: <https://www.ibm.com/think/x-force>
- [9] Microsoft, "Microsoft digital defense report 2025," 2025. [Online]. Available: <https://www.microsoft.com/en-us/corporate-responsibility/cybersecurity/microsoft-digital-defense-report-2025/>
- [10] R. Singh, S. Tariq, F. Jalalvand, M. B. Chhetri, S. Nepal, C. Paris, and M. Lochner, "LLMs in the SOC: An empirical study of human-AI collaboration in security operations centres," *arXiv preprint arXiv:2508.18947*, 2025. [Online]. Available: <https://arxiv.org/abs/2508.18947>
- [11] Anonymous, "CORTEX: Collaborative LLM agents for high-stakes alert triage," *arXiv preprint arXiv:2510.00311*, 2025. [Online]. Available: <https://arxiv.org/abs/2510.00311>
- [12] A. Lekssays, U. Shukla, H. T. Sencar, and M. R. Parvez, "TechniqueRAG: Retrieval augmented generation for adversarial technique annotation in cyber threat intelligence text," *arXiv preprint arXiv:2505.11988*, 2025. [Online]. Available: <https://arxiv.org/abs/2505.11988>
- [13] R. Fayyazi, R. Taghdimi, and S. J. Yang, "On the uses of large language models to interpret ambiguous cyberattack descriptions," *arXiv preprint arXiv:2401.00280*, 2024. [Online]. Available: <https://arxiv.org/abs/2401.00280>
- [14] Anonymous, "LanG – A governance-aware agentic AI platform for unified security operations," *arXiv preprint arXiv:2604.05440*, 2026, two-layer guardrail pipeline (regex + Llama Prompt Guard 2) achieving 98.1% F1; MCP-mediated tool exposure; AI Governance Policy Engine. [Online]. Available: <https://arxiv.org/abs/2604.05440>
- [15] Z. Ji, N. Lee, R. Frieske, T. Yu, D. Su, Y. Xu, E. Ishii, Y. J. Bang, A. Madotto, and P. Fung, "Survey of hallucination in natural language generation," *ACM Computing Surveys*, vol. 55, no. 12, p. Article 248, 2023.
- [16] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, "Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection," *arXiv preprint arXiv:2302.12173*, 2023, presented at ACM AISec '23. [Online]. Available: <https://arxiv.org/abs/2302.12173>
- [17] Y. Liu, Y. Jia, R. Geng, J. Jia, and N. Z. Gong, "Formalizing and benchmarking prompt injection attacks and defenses," in *Proceedings of the 33rd USENIX Security Symposium*. USENIX Association, 2024, pp. 1831–1847. [Online]. Available: <https://www.usenix.org/conference/usenixsecurity24/presentation/liu-yupe>
- [18] A. Zou, Z. Wang, N. Carlini, M. Nasr, J. Z. Kolter, and M. Fredrikson, "Universal and transferable adversarial attacks on aligned language models," *arXiv preprint arXiv:2307.15043*, 2023. [Online]. Available: <https://arxiv.org/abs/2307.15043>
- [19] OWASP Foundation, "OWASP top 10 for agentic applications," Dec. 2025. [Online]. Available: <https://genai.owasp.org/resource/owasp-top-10-for-agentic-applications/>
- [20] IBM Security and Ponemon Institute, "Cost of a data breach report 2025," 2025, the AI Oversight Gap edition. [Online]. Available: <https://www.ibm.com/think/x-force/2025-cost-of-a-data-breach-navigating-ai>
- [21] ENISA, "Multilayer framework for good cybersecurity practices for AI," Jun. 2023. [Online]. Available: <https://www.enisa.europa.eu/publications/multilayer-framework-for-good-cybersecurity-practices-for-ai>
- [22] Y. Ge, "Governance architecture for autonomous agent systems: Threats, framework, and engineering practice," *arXiv preprint arXiv:2603.07191*, 2026, layered Governance Architecture (LGA): four-layer framework with execution sandboxing (L1), intent verification (L2), zero-trust inter-agent authorization (L3), and immutable audit logging (L4). Bilingual benchmark of 1,081 tool-call samples; intent verification intercepts 93.0–98.5% of malicious tool calls across five LLM judges. [Online]. Available: <https://arxiv.org/abs/2603.07191>
- [23] NIST, "Artificial intelligence risk management framework (AI RMF 1.0)," National Institute of Standards and Technology, Tech. Rep. NIST AI 100-1, Jan. 2023. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/ai/nist.ai.100-1.pdf>
- [24] ISO/IEC, "ISO/IEC 42001:2023 – information technology – artificial intelligence – management system," 2023. [Online]. Available: <https://www.iso.org/standard/42001>
- [25] Brasil, "Lei nº 13.709, de 14 de agosto de 2018 – lei geral de proteção de dados (LGPD)," 2018. [Online]. Available: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/113709.htm
- [26] ANPD, "Resolução CD/ANPD nº 15, de 24 de abril de 2024 – regulamento de comunicação de incidente de segurança," 2024. [Online]. Available: https://www.gov.br/anpd/pt-br/acesso-a-informacao/institucional/atos-normativos/regulamentacoes_anpd
- [27] A. Avizienis, J.-C. Laprie, B. Randell, and C. Landwehr, "Basic concepts and taxonomy of dependable and secure computing," *IEEE Transactions on Dependable and Secure Computing*, vol. 1, no. 1, pp. 11–33, 2004.
- [28] P. Manakul, A. Liusie, and M. J. F. Gales, "SelfCheckGPT: Zero-resource black-box hallucination detection for generative large language models," in *Proceedings of the 2023 Conference on Empirical Methods in Natural Language Processing (EMNLP)*, 2023, pp. 9004–9017. [Online]. Available: <https://arxiv.org/abs/2303.08896>

- [29] OWASP Foundation, "Agentic AI – threats and mitigations," 2025. [Online]. Available: <https://genai.owasp.org/resource/agentic-ai-threats-and-mitigations/>
- [30] B. Schneier, *Applied Cryptography: Protocols, Algorithms, and Source Code in C*, 2nd ed. John Wiley & Sons, 1998.
- [31] D. Sculley, G. Holt, D. Golovin, E. Davydov, T. Phillips, D. Ebner, V. Chaudhary, M. Young, J.-F. Crespo, and D. Dennison, "Hidden technical debt in machine learning systems," in *Advances in Neural Information Processing Systems (NIPS)*, vol. 28, 2015.
- [32] A. Abuadba, N. Sultan, S. Nepal, and S. Jha, "Human society-inspired approaches to agentic AI security: The 4C framework," *arXiv preprint arXiv:2602.01942*, 2026, organizes agentic AI risks across four dimensions: Core, Connection, Cognition, Compliance. [Online]. Available: <https://arxiv.org/abs/2602.01942>
- [33] A. Kurtz and K. Krawiecka, "Who governs the machine? A machine identity governance taxonomy (MIGT) for AI systems operating across enterprise and geopolitical boundaries," *arXiv preprint arXiv:2604.06148*, 2026, ai-Identity Risk Taxonomy (AIRT) with 37 risk subcategories across eight domains; companion Machine Identity Governance Taxonomy (MIGT). Documents agent-to-human identity ratios exceeding 80:1 in enterprise environments. [Online]. Available: <https://arxiv.org/abs/2604.06148>
- [34] NIST, "AI RMF: Generative artificial intelligence profile," National Institute of Standards and Technology, Tech. Rep. NIST AI 600-1, Jul. 2024. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>
- [35] —, "The NIST cybersecurity framework 2.0," National Institute of Standards and Technology, Tech. Rep. NIST CSWP 29, Feb. 2024. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>
- [36] The MITRE Corporation, "MITRE ATT&CK enterprise," 2024, living document; accessed 2026-05-31. [Online]. Available: <https://attack.mitre.org>
- [37] —, "MITRE ATLAS – adversarial threat landscape for artificial-intelligence systems," 2025, living document; v5.1.0, accessed 2026-05-31. [Online]. Available: <https://atlas.mitre.org>
- [38] OWASP Foundation, "OWASP top 10 for large language model applications – 2025," 2024, v4.2.0a (Nov 2024). [Online]. Available: <https://genai.owasp.org/resource/owasp-top-10-for-llm-applications-2025/>
- [39] ISO/IEC, "ISO/IEC 27001:2022 – information security, cybersecurity and privacy protection – ISMS – requirements," 2022. [Online]. Available: <https://www.iso.org/standard/27001>
- [40] A. R. Hevner, S. T. March, J. Park, and S. Ram, "Design science in information systems research," *MIS Quarterly*, vol. 28, no. 1, pp. 75–105, 2004.
- [41] K. Peffers, T. Tuunanen, M. A. Rothenberger, and S. Chatterjee, "A design science research methodology for information systems research," *Journal of Management Information Systems*, vol. 24, no. 3, pp. 45–77, 2007.
- [42] M. Bhatt, S. Chennabasappa, C. Nikolaidis, S. Wan, I. Evtimov, D. Gabi, D. Song, F. Ahmad, C. Aschermann, L. Fontana, S. Frolov, R. P. Giri, D. Kapil, Y. Kozyrakis, D. LeBlanc, J. Milazzo, A. Straumann, G. Synnaeve, V. Vontimitta, S. Whaley, and J. Saxe, "Purple llama CyberSecEval: A secure coding benchmark for language models," *arXiv preprint arXiv:2312.04724*, 2023. [Online]. Available: <https://arxiv.org/abs/2312.04724>
- [43] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, "NIST SP 800-207: Zero trust architecture," National Institute of Standards and Technology, Tech. Rep. SP 800-207, Aug. 2020. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/specialpublications/NIST.SP.800-207.pdf>
- [44] F. Blefari, C. Cosentino, F. A. Pironti, A. Furfaro, and F. Marozzo, "CyberRAG: An agentic RAG cyber attack classification and reporting tool," *arXiv preprint arXiv:2507.02424*, 2025, agentic RAG framework orchestrating fine-tuned classifiers and tool adapters with iterative retrieval-and-reason loop over a domain-specific knowledge base. [Online]. Available: <https://arxiv.org/abs/2507.02424>
- [45] H. T. Neprash, C. C. McGlave, D. A. Cross *et al.*, "Trends in ransomware attacks on US hospitals, clinics, and other health care delivery organizations, 2016–2021," *JAMA Health Forum*, 2022. [Online]. Available: <https://pmc.ncbi.nlm.nih.gov/articles/PMC9856685/>
- [46] Various, "Ransomware attacks and data breaches in US health care systems," *JAMA Network Open*, 2024. [Online]. Available: <https://jamanetwork.com/journals/jamanetworkopen/fullarticle/2833984>
- [47] H. T. Neprash *et al.*, "Cybersecurity lessons from the Change Healthcare attack," *JAMA Internal Medicine*, 2024.
- [48] NSA AISC, CISA, FBI, ASD ACSC, CCCS, NCSC-NZ, and NCSC-UK, "Deploying AI systems securely: Best practices for deploying secure and resilient AI systems," National Security Agency Artificial Intelligence Security Center, Tech. Rep., Apr. 2024. [Online]. Available: <https://media.defense.gov/2024/Apr/15/2003439257/-1/-1/0/CSI-DEPLOYING-AI-SYSTEMS-SECURELY.PDF>
- [49] I. Sharafaldin, A. H. Lashkari, and A. A. Ghorbani, "Toward generating a new intrusion detection dataset and intrusion traffic characterization," in *Proceedings of the 4th International Conference on Information Systems Security and Privacy (ICISSP)*. SciTePress, 2018, pp. 108–116, introduces the CICIDS-2017 dataset with 14 attack categories captured over a five-day testbed and the CICFlowMeter feature set used as the schema reference for the synthetic generator in this paper.
- [50] C. Wohlin, P. Runeson, M. Höst, M. C. Ohlsson, B. Regnell, and A. Wesslén, *Experimentation in Software Engineering*. Springer, 2012.